



C&S
Wholesale
Grocers

Cyber Internal Network Security Assessment Executive Summary*

[10/21/2024]

*This Executive Summary is designed for the non-technical leader and complements Internal Audit's full-length report "C&S IA_FY24 Cyber Internal Network Security Assessment Full Report"

Scope and Objectives

Cyber Internal Network Security Assessment

Scope

Internal Audit performed a network review, an Active Directory review, and an attack and penetration assessment on the C&S network, applications and related infrastructure to discover the risk of exposure to cyber security threats and vulnerabilities. Internal Audit assessed the internal C&S network, including servers, workstations, and other network devices available through the internal environment.*

Findings resulted from Internal Audit's attempt to discover, validate, and exploit vulnerabilities within the project's duration. The activities performed attempt to illustrate the risks associated with tactics, techniques, and procedures utilized by adversaries attempting to compromise C&S. The recommendations provided are structured to facilitate remediation of the identified security risks.

Objectives

- Gain access to sensitive information without any pre-existing technical knowledge of the internal C&S network infrastructure.
- Identify network vulnerabilities and paths to privilege escalation assuming only a basic entry point.
- Review the Active Directory configuration of the Windows domain to determine misconfigurations and assess overall security hygiene.
- Develop pragmatic recommendations to further strengthen the company's cyber security posture.

*Testing performed as part of this scope of work leveraged an Ethernet connection on-site, which assumes a committed attacker can access the "front door" of the C&S network and evaluates security vulnerabilities once an attacker is "inside." External network penetration testing (i.e. trying to "break in" from the internet) or social engineering testing (i.e. sophisticated phishing attempts to deceive users into providing entry to an attacker) were out of scope for this assessment.

Approach and Methodology

Cyber Internal Network Security Assessment

Approach and Methodology

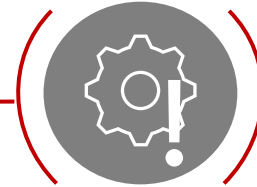
The assessment was completed through hands-on-keys technical testing without any prior knowledge of the C&S environment, by performing the key steps described below. The assessment identified detailed technical findings and recommendations prioritized by level of risk. These technical findings were then grouped into thematic observations.



1) Profile: Create an internal profile or "footprint" from computer addresses and network domains using proprietary and public tools.



2) Assess: Scan the computer addresses programmatically to identify vulnerabilities by using a combination of public, proprietary and commercially available tools.



3) Exploit: Attempt to exploit the vulnerable systems. Proprietary EY tools and techniques, as well as publicly available exploits, were used to circumvent the security of the selected systems.

Summary of Results and Key Areas for Improvement

Cyber Internal Network Security Assessment

Summary of Results

- Internal Audit identified two distinct attack vectors through which an unauthorized user could achieve administrative privileges over C&S's Active Directory domains.
- Furthermore, internal audit discovered various misconfigurations within Active Directory that could be exploited for privilege escalation or lateral movement.
- These findings highlight **significant vulnerabilities** in C&S's network security posture.

Key Areas for Improvement



Security Settings and Configurations

- Enforce stronger password requirements and educate employees on the dangers of creating easily guessed passwords
- Review sharing configurations for all network file shares and implement encryption
- Implement security monitoring on any networks that are not currently monitored
- Implement network segmentation in C&S network



Privileged Access Management

- Implement least privilege model when assigning access to accounts and restrict password sharing
- Review the number of users with highly privileged access

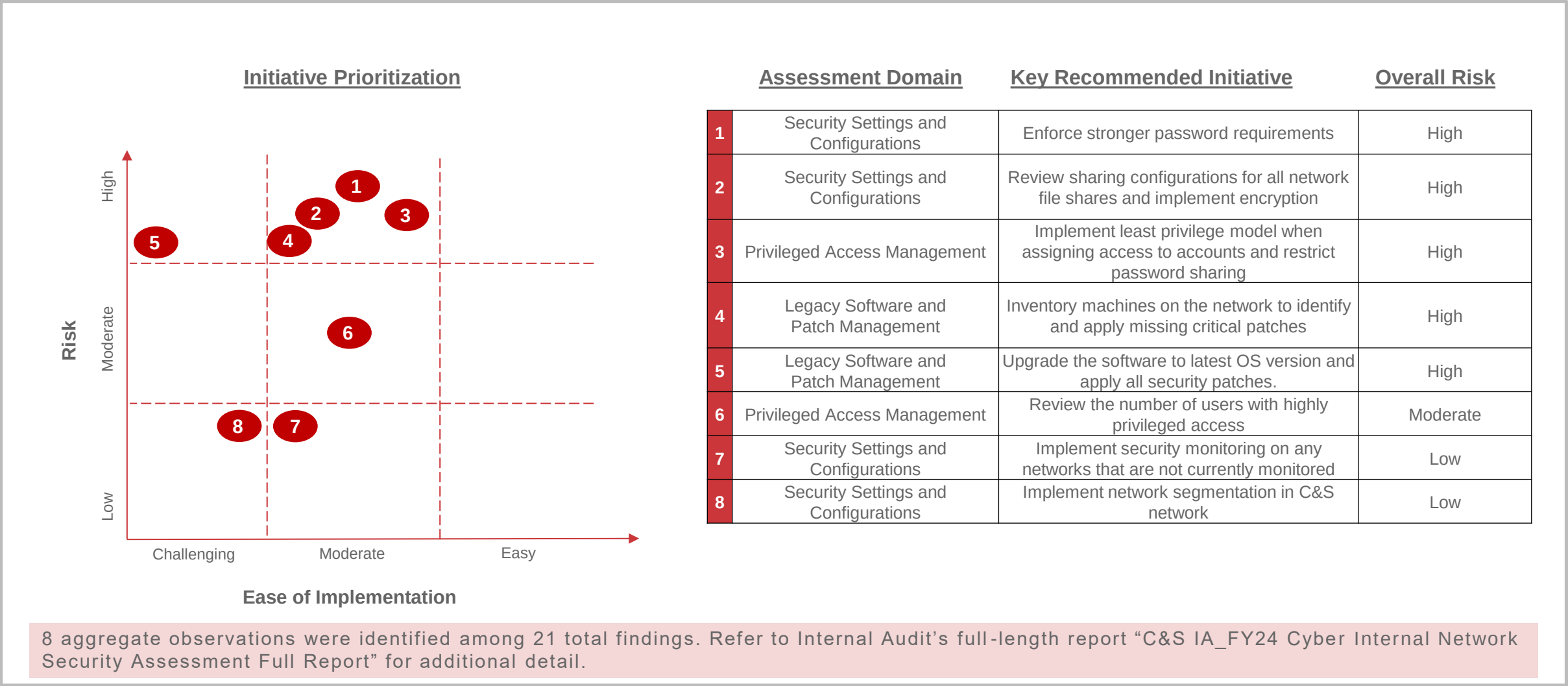


Legacy Software and Patch Management

- Inventory machines on the network to identify and apply missing critical patches
- Upgrade the software to latest OS version and apply all security patches. Accelerate (where practical) plans to address systems unable to be patched or upgraded.

Recommended Initiative Prioritization

Risk reduction vs. Ease of implementation



Appendix C: Cybersecurity- Key Findings

Observation	Risk/Impact	Management Action Plan
1 <u>Passwords</u> : Enforce stronger password requirements	Weak password standards (both end users and back-end IT administrators) increase the company's vulnerability to an array of cyber intrusions and attacks.	TBD
2 <u>Data sharing</u> : Review sharing configurations for all network file shares and implement encryption	Weak access controls over network file sharing sources allow an attacker easier access to sensitive and proprietary data on the network.	TBD
3 <u>Privileged access assignment</u> : Implement least privilege model when assigning access to accounts and restrict password sharing	Granting users (both end users and back-end IT administrators) privileges in excess of what is needed for routine responsibilities, or sharing the same password across multiple admin accounts, increases the number of accounts and opportunities that an attacker can exploit to gain unauthorized administrative access.	TBD
4 <u>Patch management</u> : Inventory machines on the network to identify and apply missing critical patches	Untimely application of vendor security patches increase the window of time that an attacker can exploit vulnerabilities.	TBD
5 <u>Legacy systems</u> : Upgrade the software to latest OS version and apply all security patches	Legacy systems that are no longer supported by vendors or are technically unable to be upgraded or patched increase the volume of potential security vulnerabilities that an attacker can exploit.	TBD

Appendix C: Cybersecurity- Key Findings

Observation	Risk/Impact	Management Action Plan
6 Privileged access: Review the number of users with highly privileged access	A large volume of users with administrative rights increases the number of accounts and opportunities that an attacker can exploit to gain unauthorized administrative access.	TBD
7 Security monitoring: Implement security monitoring on any networks that are not currently monitored	Attackers can gain entry to unmonitored network domains as an entry point to more operationally critical or sensitive domains.	Not Required (Risk ranked Low)
8 Network segmentation: Implement network segmentation in C&S network	A “flat network” allows an attacker to more easily navigate across areas of the network unimpeded.	Not Required (Risk ranked Low)